Lab 5 – Web Security, WAF & OWASP using DVWA

Send your report only to <csclass.dz@gmail.com>
Team information (one report by team)

- Boulgamhe Lahcen Nidhal

Deadline: Monday, Apr 20, 2026

By the end of this lab, you will

- Understand WAFs and their role in cybersecurity
- Relate attacks to OWASP Top 10
- Perform web attacks on DVWA
- Understand the limitations of traditional firewalls vs WAF
- Practice basic pentesting workflow

General questions

- What is a WAF?

  A **Web Application Firewall (WAF)** is a security control that monitors, filters, and blocks HTTP/HTTPS traffic between clients and a web application. It protects against common web attacks such as SQL Injection, Cross-Site Scripting (XSS), and other application-layer threats by analyzing requests and responses based on predefined rules or behavioral models.

- Where is a WAF placed in a network?

  A **Web Application Firewall (WAF)** is placed **between the client and the web application/server**. It acts as a reverse proxy that inspects all incoming and outgoing HTTP/HTTPS traffic.

  Client → WAF → Web Server / Application → Database

- Difference between Firewall (NGFW) and WAF.

  An NGFW operates primarily at the network level (Layers 3–4, with some Layer 7 awareness). It is designed to monitor and control traffic based on IP addresses, ports, protocols, and connection states. NGFWs provide capabilities such as intrusion prevention, application awareness, and protection against network-based attacks like port scanning, malware propagation, and unauthorized access. It is typically deployed at the network perimeter to protect the entire infrastructure.

  In contrast, a WAF operates specifically at the application layer (Layer 7) and focuses on HTTP/HTTPS traffic. It is designed to understand the structure and behavior of web applications, allowing it to detect and block application-layer attacks such as SQL Injection, Cross-Site Scripting (XSS), and other OWASP Top 10 vulnerabilities. A WAF is usually placed in front of web servers as a reverse proxy, inspecting and filtering requests before they reach the application.

- Can a WAF stop all attacks?

  No. A WAF cannot stop all attacks.

It is effective against common web attacks (e.g., SQLi, XSS), but it can be bypassed and cannot detect complex issues like business logic flaws or zero-day vulnerabilities. It should be used as an additional security layer, not a complete solution.

- How can attackers bypass a WAF? If yes, give one example of how an attacker could bypass a WAF.
- Name at least three free and open-source WAFs and briefly describe one of them.

Yes, attackers can bypass a WAF by modifying their requests so they do not match detection rules.

Example:
An attacker may use **encoding/obfuscation** to hide a malicious payload.
For instance, a SQL Injection payload can be encoded (URL encoding) so the WAF does not recognize it, while the backend server decodes and executes it.

- What is OWASP?

OWASP is a non-profit organization focused on improving the security of software, especially web applications.

- Why is the OWASP Top 10 important for SOC analysts?

The **OWASP Top 10** is important for SOC analysts because it highlights the most common and critical web application vulnerabilities they are likely to encounter.

It helps SOC analysts to:

- **Prioritize alerts:** focus on high-risk attack patterns (e.g., SQLi, XSS)
- **Improve detection:** create better SIEM rules and use cases based on real threats
- **Understand attacker behavior:** recognize how web attacks are performed
- **Respond faster:** identify and investigate incidents more efficiently

In short, it provides a practical baseline for monitoring, detection, and incident response related to web application attacks.

- Provide the current OWASP Top 10 (just name them and indicate your source)

Broken Access Control
Cryptographic Failures
Injection
Insecure Design
Security Misconfiguration
Vulnerable and Outdated Components
Identification and Authentication Failures
Software and Data Integrity Failures
Security Logging and Monitoring Failures
Server-Side Request Forgery (SSRF)
The sourece is the offical site of OWSAP

Top 10:2025 List

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

- Explain one OWASP vulnerability
  Cryptographic Failures refer to weaknesses related to the protection of sensitive data when it is stored or transmitted. This vulnerability occurs when an application fails to properly implement encryption mechanisms, or uses weak or outdated cryptographic algorithms, leaving confidential information exposed

Lab environment (2 VMs)

- **Attacker VM:** Kali Linux
- **Victim VM:** Metasploitable 2 (with DVWA) (i use RHEL VM instead for butter UX)

DVWA Setup

Network Verification Step

- What is the IP of the victim?

  10.235.18.152

```
: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group defaul
 qlen 1000
   inet 10.235.18.152/24 brd 10.235.18.255 scope global dynamic noprefixroute ens16
```

- Can the attacker reach the victim?

```
┌──(ababil㉿AALIIWAAMRA)-[~]
└─$ ping 10.235.18.152
PING 10.235.18.152 (10.235.18.152) 56(84) bytes of data.
64 bytes from 10.235.18.152: icmp_seq=1 ttl=64 time=1.14 ms
64 bytes from 10.235.18.152: icmp_seq=2 ttl=64 time=1.13 ms
64 bytes from 10.235.18.152: icmp_seq=3 ttl=64 time=0.900 ms
^C
--- 10.235.18.152 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 0.900/1.055/1.142/0.110 ms
```

Yes the attacker can rich the victim because they are at the same LAN

Why is this important?

It is necessary for perform reconicene and apply exploit againset the victim if there no Netorek between them we can do nothing

Reconnaissance Step

- What services are running on the victim machine?

  There is lot of service such as ftp http (apache and node js) also ssh

```
└─$ nmap -sV 10.235.18.152

Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 13:40
Nmap scan report for 10.235.18.152
Host is up (0.0024s latency).
Not shown: 984 filtered tcp ports (no-response), 10 filtere
rts (admin-prohibited)
PORT     STATE  SERVICE    VERSION
21/tcp   closed ftp
22/tcp   open   ssh        OpenSSH 8.7 (protocol 2.0)
80/tcp   open   http       Apache httpd 2.4.25 ((Debian))
1080/tcp open   http       Node.js Express framework
1433/tcp open   ms-sql-s   Microsoft SQL Server
9090/tcp closed zeus-admin
1 service unrecognized despite returning data. If you know
ice/version, please submit the following fingerprint at htt
p.org/cgi-bin/submit.cgi?new-service :
SF-Port1433-TCP:V=7.99%I=7%D=4/20%Time=69E61ED0%P=x86_64-pc
nu%r(ms
SF:-sql-s,25,"\x04\x01\0%\0\0\x01\0\0\0\x15\0\x06\x01\0\x1b
02\0\x1
SF:c\0\x01\x03\0\x1d\0\0\xff\x11\0\x0f\xc3\0\0\0\0");
MAC Address: 14:AB:C5:69:D5:2A (Intel Corporate)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect re
 https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.93 second
```

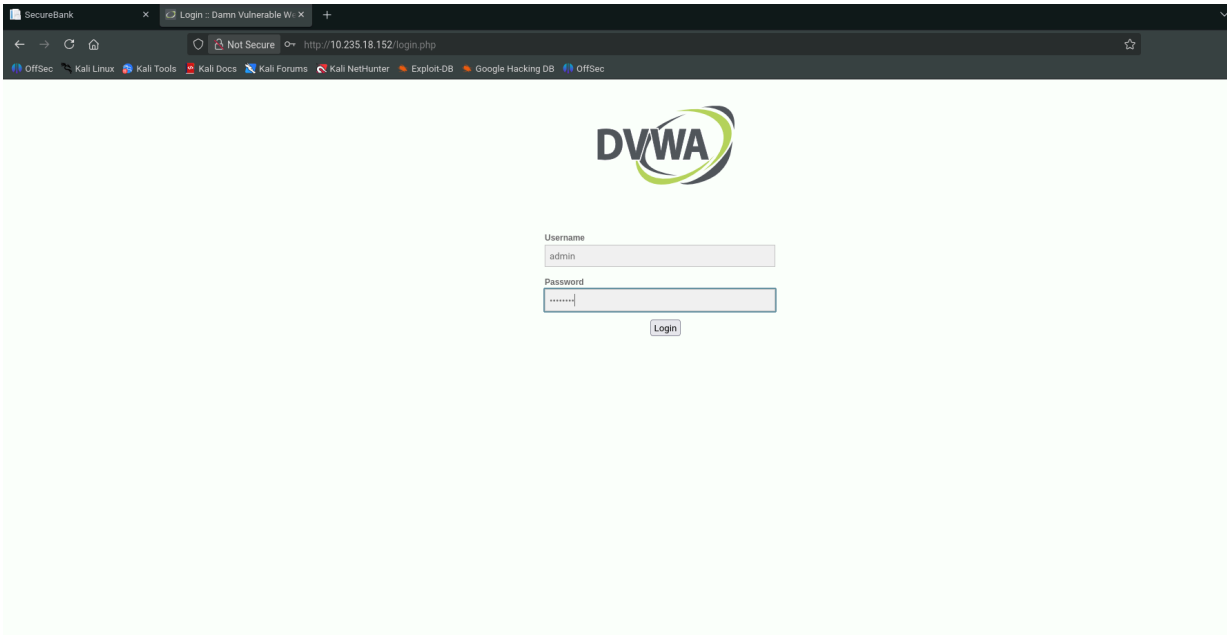
- Which port hosts the web application?

  In my case I set in the default port (80)

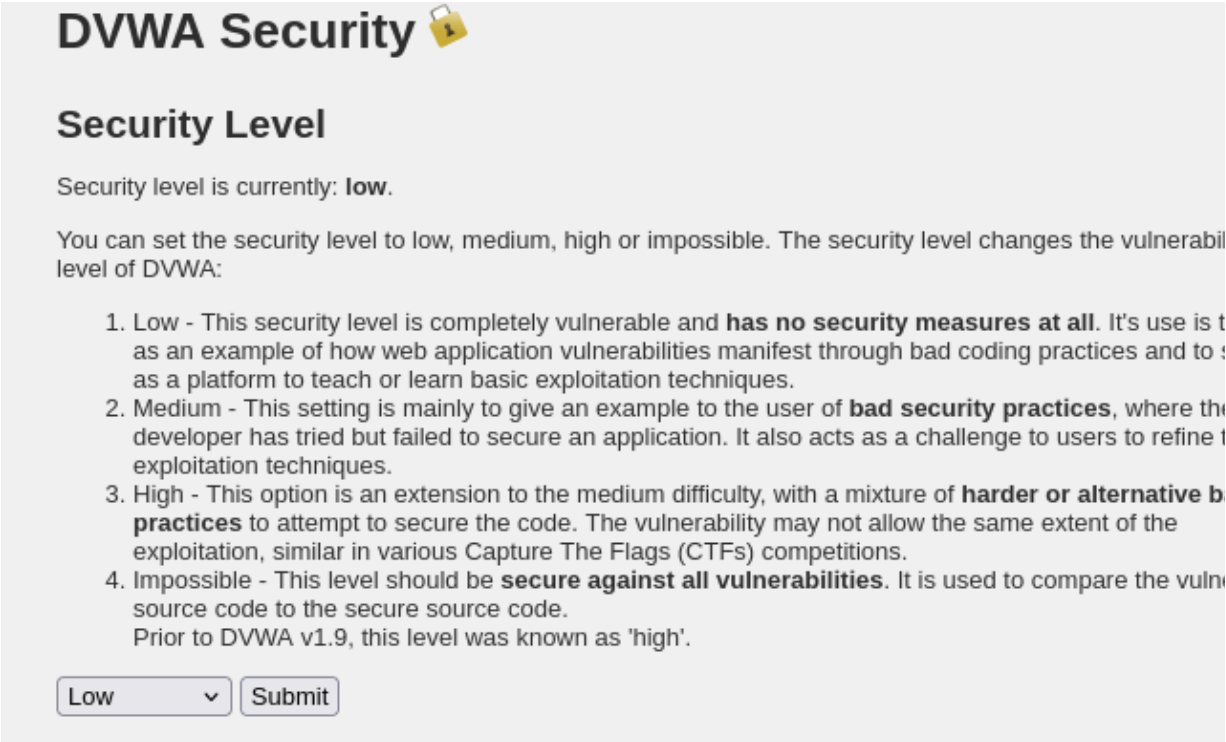
Setup step

- Access DVWA from Kali.

  I run DVWA in docker the username = admin , password =password



- Set Security Level to **Low.**



Questions

- What is DVWA, and why is it used in cybersecurity training?

DVWA (Damn Vulnerable Web Application) is an intentionally insecure web application designed for cybersecurity training and practice.

It is used to safely simulate real-world web vulnerabilities in a controlled environment, allowing learners to practice exploitation techniques without legal or ethical risks.

- DVWA provides different security levels (Low, Medium, High). What is the purpose of these levels, and how do they affect the success of attacks?

DVWA provides different security levels to simulate how real applications evolve from insecure to more secure implementations.

Purpose of Security Levels

These levels are designed to:

1. Low Security

- No or minimal input validation
- No filtering or encoding
- Attacks (SQLi, XSS, etc.) work easily

2. Medium Security

- Basic input filtering or sanitization
- Simple protections (e.g., blacklists)
- Some attacks fail or need bypass techniques

3. High Security

- Strong validation and filtering
- Better input handling and output encoding
- Many common payloads are blocked

- Why is DVWA intentionally vulnerable, and why would using it in a real production environment be dangerous?
  "DVWA is an insecure-by-design application meant strictly for isolated lab environments. Its presence in a production network constitutes a critical vulnerability, as it provides a pre-built pathway for attackers to achieve Remote Code Execution (RCE) and move laterally across the infrastructure."
- How could a WAF protect DVWA from attacks such as SQL Injection or XSS? Give two specific examples.

A **DVWA** could be protected by a Web Application Firewall by filtering and blocking malicious HTTP requests before they reach the application.

Example 1 – SQL Injection Protection:
A WAF can detect SQL injection patterns such as `' OR 1=1 --` in URL parameters or form inputs and block the request or sanitize it before it reaches the database query layer.

Example 2 – XSS Protection:
A WAF can identify and block scripts like `<script>alert(1)</script>` in input fields or URL parameters, preventing the malicious JavaScript from being executed in the user's browser.

- Match some DVWA vulnerabilities to OWASP.

DVWA → OWASP Mapping

- **SQL Injection (DVWA)** → *Injection*

(OWASP Top 10: A03 – Injection)

- **Cross-Site Scripting (XSS)** → *Injection*
  (OWASP Top 10: A03 – Injection)
- **Command Injection** → *Injection*
  (OWASP Top 10: A03 – Injection)
- **File Inclusion (LFI/RFI)** → *Security Misconfiguration*
  (OWASP Top 10: A05 – Security Misconfiguration)
- **Weak Login / Brute Force** → *Identification and Authentication Failures*
  (OWASP Top 10: A07 – Authentication Failure

Attack 1 — SQL Injection

Attack DVWA using SQL injection.

- Access DVWA and perform a simple SQL Injection attack. What input did you use, and what was the result? Explain why the attack works.
  - What did you do?
  - What happens?
  - Why does it work?

Attack 2 — XSS

Attack 3 — Command

Injection Attack 4 — File

Inclusion Attack 5 — CSRF

(Advanced) Questions

- Would a traditional firewall stop these attacks?
- Would a WAF stop them?

- How to perform the above attacks (2 to 5)
  - Provide screenshots
  - Explanation
  - After each attack, add how this vulnerability could be prevented.

Try the same attacks in Low and Medium. What changes? Why?